Hands On Pertemuan 3

Nama: Muhammad Bilal Dzakwan Razin
NIM: 1002250037

Nama: ARIF HILMAN KHALIS
NIM: 1002250019

Tanggal: 14 Oktober 2026

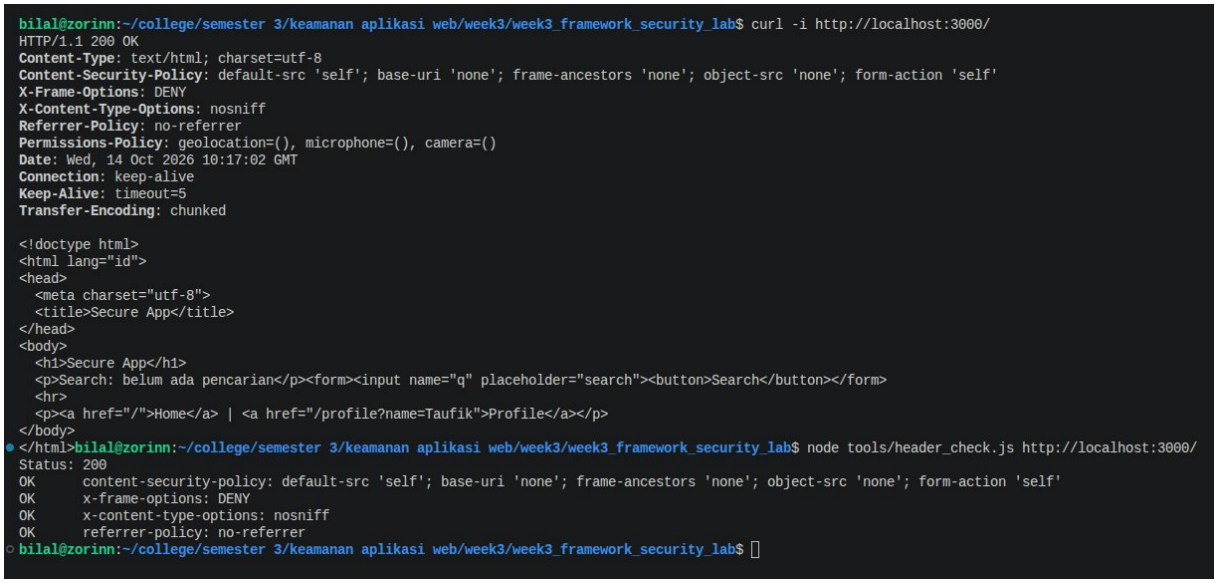
Ringkasan temuan

Pengujian langsung di browser menunjukkan baseline merender **halo** sebagai HTML tebal dan payload script memunculkan dialog alert. Secure menampilkan kedua payload sebagai teks tanpa dialog alert. Screenshot terminal membuktikan baseline HTTP 200 dengan empat header MISSING, sedangkan secure HTTP 200 dengan keempat header OK. Review kode serta 40 pemeriksaan handler mengonfirmasi escaping dan menunjukkan respons 404 secure belum mendapat header tersebut. Lodash 4.17.11 tidak dipanggil handler. Bukti startup baseline dilengkapi pada 15 Oktober 2026.

Jawaban Lampiran A

Pertanyaan	Jawaban mahasiswa
Perbedaan baseline vs secure headers	Output HTTP dan checker: baseline tidak memiliki empat header yang diperiksa. Secure memiliki CSP, X-Frame-Options DENY, X-Content-Type-Options nosniff, dan Referrer-Policy no-referrer; semuanya OK. Respons secure juga memiliki Permissions-Policy.
Payload rendering dan hasil observasi	Browser baseline: halo menjadi elemen B dan teks tebal; payload script memunculkan alert. Browser secure: kedua payload tampil sebagai teks literal dan pengujian script tidak memunculkan alert. DOM secure memuat halo.
Source dan sink yang ditemukan	Source: url.searchParams.get('q') dan get('name'). Sink: interpolasi ke body HTML lalu res.end(page(...)). Secure menambahkan escapeHtml() sebelum interpolasi.
Dependency atau advisory yang diprioritaskan	Lodash 4.17.11 memiliki advisory high. Kedua handler tidak mengimpor Lodash sehingga reachability eksploit lewat fitur lab belum terbukti. Rendering yang langsung menerima input diprioritaskan.
Rekomendasi teknis utama	Terapkan escaping sesuai konteks, secure headers secara konsisten, dan hapus atau update dependency sesuai advisory.
Cara validasi perbaikan	Ulangi payload pada / dan /profile; periksa header melalui curl/checker, termasuk path 404. Setelah update dependency, jalankan audit dan uji regresi.
Refleksi akhir	Framework dan middleware membantu konsistensi kontrol. Developer tetap menentukan konfigurasi, konteks escaping, authorization, serta prioritas patch. Starter ini memakai Node HTTP; Express dan Helmet belum digunakan.

Gambar 1 Secure HTTP 200 dan empat header keamanan OK



Checklist SAST manual

Lokasi	Source dan sink	Kontrol dan rekomendasi
Baseline / Baris 24 dan 29	q dari query -> HTML Search -> res.end	Escaping dan secure headers hilang. Escape output dan terapkan kebijakan header.
Baseline /profile Baris 34 dan 36	name dari query -> HTML Nama -> res.end	Escaping dan secure headers hilang. Lindungi output name dan uji route profile.
Secure / dan /profile Baris 44 sampai 55	q/name -> escapeHtml -> HTML -> res.end	Escaping dan secure headers tersedia pada kedua route. Pertahankan kontrol saat menambah fitur.
Secure 404 Baris 59 dan 60	Path tidak dikenal -> not found	Hanya Content-Type text/plain. Terapkan header keamanan dengan mempertahankan tipe konten error.

Tidak ditemukan SQL, session, eval, atau innerHTML pada kedua aplikasi. Missing header adalah kelemahan konfigurasi, bukan otomatis bukti eksploit. Escaping yang diuji sesuai konteks HTML body.

Dependency advisory triage

Package dan versi	Severity dan dampak	Fix dan prioritas
lodash 4.17.11 Manifest dan sampel	High menurut sampel dan advisory. Prototype pollution atau command injection pada fungsi tertentu. Belum dipanggil handler.	Hapus jika tidak diperlukan; bila diperlukan, kandidat update 4.18.1 lalu audit dan uji regresi. Prioritas setelah celah rendering; meningkat jika fungsi rentan reachable.
example old template engine 1.0.0 Hanya sampel	Medium menurut sampel. Potensi XSS bila auto-escaping mati. Tidak ada di manifest.	Contoh latihan, bukan dependency aktual. Jika digunakan, aktifkan auto-escaping dan update.

Analisis memakai advisory-sample.json dan advisory resmi, bukan hasil npm audit atau bukti instalasi. Patch tersedia; perubahan versi tetap perlu diuji untuk mendeteksi perubahan perilaku.

Rekomendasi dan validasi

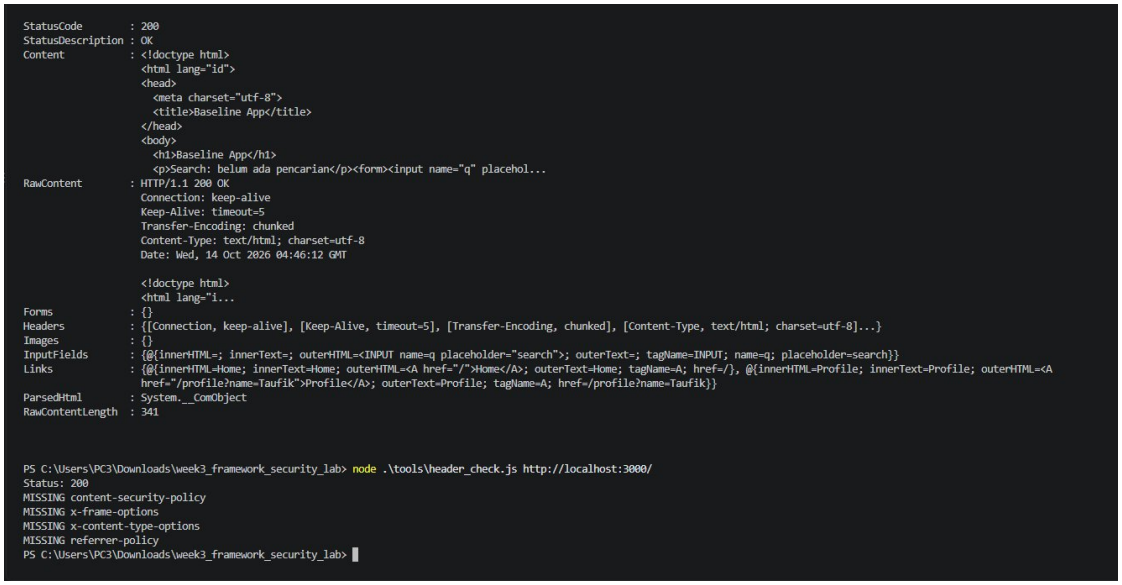
No	Tindakan dan bukti	Validasi
1	Escape output user. Baseline menghasilkan tag script mentah pada kedua route.	Uji script, bold, dan karakter & < > " '. Secure harus mengirim entities.
2	Sentralisasi secure headers. Respons 404 secure belum konsisten.	Periksa /, /profile, dan path 404 melalui curl dan checker.
3	Hapus atau update dependency. Manifest mencantumkan Lodash lama tanpa pemakaian.	Periksa dependency tree, audit, dan fungsi aplikasi setelah perubahan.

Evidence praktik

Gambar 0 Baseline berhasil dijalankan pada localhost 3000

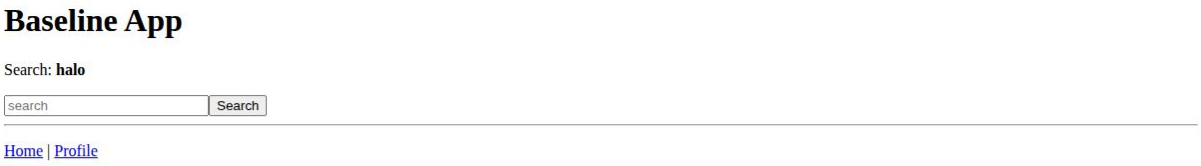


Gambar 2 Baseline HTTP 200 dan empat header MISSING



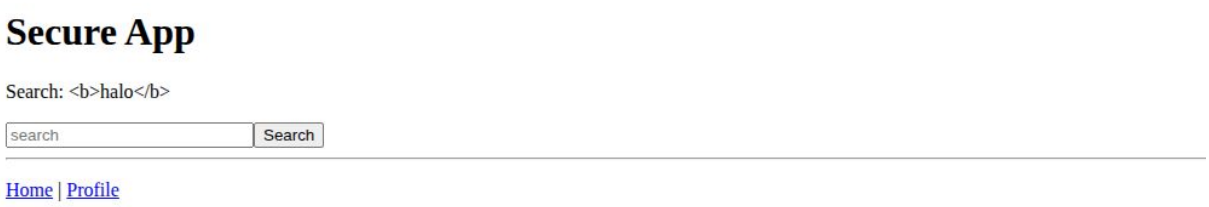
Terlihat StatusCode 200, judul Baseline App, dan checker MISSING untuk CSP, X-Frame-Options, X-Content-Type-Options, serta Referrer-Policy. Perintah curl pada gambar menghasilkan output Invoke-WebRequest dari PowerShell.

Gambar 3 Baseline merender payload HTML sebagai teks tebal



Payload q=halo menghasilkan elemen DOM halo. **Pengujian q=<script>alert(1)</script> juga memunculkan dialog alert**; dialog ditutup setelah diverifikasi. Screenshot diambil pada hasil rendering HTML.

Gambar 4 Secure memperlakukan payload HTML sebagai data



Payload yang sama tampil literal sebagai halo. DOM: Search: halo . Pengujian script juga dilakukan langsung dan tidak memunculkan dialog alert.